

정보보안 담당자 지원

미디어솔루션에서 1년 11개월 동안 대형병원, 대형 컨벤션센터, 5성급 호텔 고객사의 서버와 웹 서비스를 맡으며 침해사고 대응, 접근통제, 백업 설계를 직접 했습니다. 퇴사 후에는 생성형 AI를 쓸 때 생기는 개인정보 유출과 소스코드 취약점 문제를 다루는 도구를 만들어 GitHub에 공개했습니다. 정보보안기사를 취득했고 CISA 시험에 합격했습니다.

메일 tkops365@gmail.com
전화 [010-4678-3603](tel:010-4678-3603)
GitHub github.com/ki0915
포트폴리오 ki0915.github.io/Profile/docs

주요 경험

HIGHLIGHTS

침해사고 2건

고객사 웹 서버 침해사고 2건을 현장에서 대응했습니다. IIS 로그와 실행 프로세스로 루트킷을 추적했고, 데이터를 검증해 AWS로 재구축했습니다. 사고를 알게 된 날부터 복구를 마칠 때까지 4일이 걸렸습니다.

점검 전체 통과

병원 보안점검에 납품사로 대응해 납품한 CMS 전체가 통과했습니다. 인증 처리의 경쟁 조건을 찾아 고치고, RBAC와 비밀번호 변경 주기, 로그인 실패 잠금을 넣었습니다.

하루 만에 복구

제가 다시 설계한 백업으로 회사가 랜섬웨어 사고를 데이터 손실 없이 하루 만에 복구했습니다. 스냅샷 하나뿐이던 백업을 변경 제한 볼륨, AWS 서버 이미지, MSSQL 복제로 나눴습니다. 사고는 퇴사 직후인 2025년 4월에 났습니다.

탐지 10 → 56건

개인정보 유출 방지 프록시 Mcp-Guard의 우회 탐지를 60건 중 10건에서 56건으로 늘렸습니다. 전각 숫자, 띄어 쓴 숫자, Base64를 풀어서 검사하게 바꿨고 정상 표본 30건에서 오탐은 없었습니다.

121건 중 111건

LLM 기반 취약점 진단 도구 ETK-Scanner로 SecurityEval 취약 코드 121건 중 111건을 찾았습니다. 이 도구를 활용해 분석한 오픈소스 인가 결함을 제보했고, 유지관리자에게서 영감이 있다는 확인을 받았습니다.

경력

EXPERIENCE

미디어솔루션 연구개발팀 사원 (병역특례)

2023.04 – 2025.03, 1년 11개월

키오스크 CMS를 개발해 납품하고 고객사 서버 운영까지 맡는 회사입니다. 대형병원, 대형 컨벤션센터, 5성급 호텔 2곳의 서버와 웹 서비스를 담당했습니다.

고객사 웹 서버 침해사고 대응

[사례 자세히 >](#)

- 1차는 KISA 침해 통보로, 2차는 서비스 중단 신고로 알게 됐고 두 번 모두 현장에 나가 대응했습니다.
- 1차 때는 현장 시스템 접근과 관리자 계정부터 되찾았습니다. IIS 로그와 응용프로그램 풀의 실행 프로세스를 맞춰 보며 루트킷을 추적했고, 구형 미들웨어와 웹 필터의 취약점을 조치했습니다.
- 2차 때는 CPU와 메모리 과점유, 공격자가 설치한 가상화 환경에서 크립토마이닝 의심 징후를 확인했습니다. ASP.NET 4.7.1을 공개 CVE와 하나씩 대조해 취약한 구성을 찾았습니다.
- 서버를 새로 세우는 쪽으로 의사결정을 도왔습니다. MSSQL 데이터는 격리 PC에서 무결성을 확인해 꺼냈고, AWS EC2와 RDS에 서비스를 다시 올렸습니다. Security Group은 운영 IP만 허용하고 RDP를 막았습니다.
- 사고를 알게 된 날부터 복구를 마칠 때까지 4일이 걸렸고, 이관 뒤 퇴사할 때까지 같은 원인의 재발은 없었습니다. 기술 담당자에게는 취약 구성을, 경영진에게는 중단과 복구 비용을 따로 설명했고 클라우드 이관과 정기 서버 관리에 합의했습니다.

병원 키오스크 CMS 개발과 보안점검 대응

[사례 자세히 >](#)

- 병원 키오스크 약 200대를 원격으로 관리하는 CMS를 혼자 설계하고 개발했습니다(TypeScript, Express, Angular, Redis, WebSocket). 화면 미러링, 원격 명령, 예약 배포와 그룹 배포, 롤백을 넣어 원격으로 풀 수 있는 장애는 현장에 가지 않고 처리했습니다.
- 이 CMS가 병원 보안점검 대상이 되어 수검에 대응했고, 납품한 CMS 전체가 점검을 통과했습니다.
- 병원 보안 요구에 맞춰 인증과 권한 구조를 고치면서, Redis 세션 검증이 끝나기 전에 임시 권한이 먼저 붙는 경쟁 조건(Race Condition)을 찾아 수정했습니다.

- 관리자와 운영자 권한은 RBAC로 나눴습니다. JWT는 서버 개인키로 서명하고 비밀번호는 bcrypt로 해시했으며, 90일 변경과 재사용 금지, 로그인 실패 잠금을 적용했습니다.
- 망분리된 병원 내부망에서는 NICE 본인인증에 필요한 경로만 열고 인증 이력은 한곳에서 관리했습니다.

서버 통합과 백업 재설계

[사례 자세히 >](#)

- 노후 서버 7대를 하나씩 점검해 Windows Server 2022와 Hyper-V로 합쳤습니다. 인바운드는 기본 차단으로 바꾸고, 웹과 DB 서버에 외부에서 바로 원격 접속하던 경로를 없앴습니다.
- Hyper-V 스냅샷 하나뿐이던 백업을 변경 제한 백업 볼륨, AWS 서버 이미지, MSSQL 복제로 나눴고, API 서버는 이중화했습니다. 백업 접근은 사내 게이트웨이 IP 중심으로 제한하고 복구 절차를 썼습니다.
- 퇴사 직후인 2025년 4월 회사에 랜섬웨어 사고가 났고, 회사는 이 백업으로 **데이터 손실 없이 하루 만에 복구**했습니다.

호텔 서버 운영과 장애 처리

[사례 자세히 >](#)

- SSL VPN으로 호텔 서버에 접속해 관리자 페이지, DB, 서버 상태를 점검했습니다. Grafana와 Prometheus로 CPU, 메모리, 스왑, 컨테이너 자원을 보며 임계치에 닿기 전에 조치했습니다.
- 배포 때마다 남은 Docker 이미지와 중지된 컨테이너가 디스크를 채워 서비스가 멈춘 적이 있습니다. 이 둘을 원인으로 확인해 정리했고, 같은 정리를 cron에 등록해 재발을 막았습니다.
- 별개로 MariaDB 로그가 쌓여 생긴 장애를 해결했습니다. 로그와 이미지 정리 절차, 서버 운영 점검 기준(체크리스트)을 문서로 남겼고, 지원이 끝난 Ubuntu 18.04는 22.04로 올렸습니다.

AI 보안 프로젝트

PROJECTS

퇴사 후 진행한 개인 프로젝트입니다. 프로젝트 이름과 저장소 주소를 누르면 GitHub로, '소개 페이지'를 누르면 포트폴리오의 설명 페이지로 이동합니다.

Mcp-Guard

2026.07

생성형 AI와 MCP 통신의 개인정보 유출 방지(DLP) 프록시

Python, MCP stdio JSON-RPC, SSE, Docker, Helm github.com/ki0915/Mcp-Guard [소개 페이지 >](#)

- LLM API나 MCP 도구 호출에 섞여 나가는 주민등록번호, 카드번호, API 키를 탐지해 가리거나 막습니다. 일반 HTTP 프록시로는 MCP stdio 통신을 볼 수 없어서 HTTP 리버스 프록시와 stdio JSON-RPC 어댑터를 함께 만들었습니다.
- 주민등록번호는 체크섬과 날짜로, 카드번호는 Luhn과 IIN으로 한 번 더 검증해 오탐을 줄였습니다. 검사 중 오류가 나면 요청을 통과시키지 않고(fail-closed), 감사 로그에는 원래 값을 남기지 않습니다.
- 띄어 쓴 숫자, 전각 숫자, Base64로 감싼 값을 풀어서 검사하게 바꾼 뒤 합성 우회 표본 60건 중 **탐지가 10건에서 56건으로** 늘었습니다. 정상 표본 30건에서 오탐은 없었습니다.
- 로컬 측정에서 요청당 추가 지연은 평균 3.10ms였습니다. 테스트 165건과 Docker, Helm 배포 구성을 함께 공개했습니다.

ETK-Scanner

2026.07

비용 상한을 둔 LLM 기반 소스코드 취약점 진단 도구(SAST)

Python AST, JS/TS, Claude API, SARIF 2.1.0, GitHub Actions github.com/ki0915/etk-scanner [소개 페이지 >](#)

- 모든 함수를 비싼 모델에 넣으면 개인이 감당하기 어려운 비용이 나옵니다. Python AST와 JS/TS 패턴으로 인증이나 검증을 하는 함수 후보를 먼저 좁히고, 저비용 모델이 거른 소수만 고성능 모델로 검증하게 했습니다. 예산 상한에 닿으면 멈춥니다.
- 결과는 CWE, 심각도, 파일 위치가 담긴 SARIF 2.1.0으로 내보내 GitHub Security 탭에 올립니다. 심각도 high 결과가 나오면 GitHub Actions job이 실패합니다.
- **SecurityEval 취약 코드 121건 중 111건을** 찾았습니다. 직접 만든 실습 백엔드에서 찾은 하드코딩 JWT 서명 키(CWE-798)로 위조한 토큰은 수정 전에는 200으로 통과했고 수정 후에는 401로 막혔습니다.
- 이 도구를 활용해 오픈소스 프로젝트의 인가 처리 결함을 분석해 제보했고, 유지관리자에게서 영향이 있다는 확인과 함께 고치겠다는 답을 받았습니다.

AI 에이전트 행동 감사 파일럿, AI와 협업해 만든 개인 프로젝트

Node.js, SQLite 비공개 저장소 [소개 페이지 ↗](#)

- AI 에이전트가 어떤 근거와 권한으로 움직였는지 사람이 나중에 확인할 수 있게, 행동과 도구 결과, 참고자료를 해시 체인과 서명 체크포인트로 기록했습니다.
- 근거나 정책이 바뀌면 이전 판정을 재검토로 되돌리고, 근거가 부족한 항목은 준수율 계산에 넣지 않았습니다.

점검과 모의해킹 실습, 저술

LABS & WRITING

월간 보안 점검 체크리스트 스크립트

2026.10

개인 랩, AI와 협업해 만들고 클라우드 Linux VM에서 직접 실행

Python, Bash, Docker, systemd timer [소개 페이지 ↗](#)

KISA 주요정보통신기반시설 가이드의 Unix 계정과 권한 10개 항목을 점검하고, 지난달 결과와 비교해 미조치 항목의 경과일을 계산합니다. 실무 디스크 장애도 1GiB 디스크로 재현해, 정리 없이 14번 중 7번 실패하던 배포를 단계형 정리로 모두 성공시켰습니다.

TryHackMe 모의해킹 실습

허가된 실습 환경

Nmap으로 서비스를 열거하고, SMB 익명 접근과 IIS 공유 디렉터리 설정 오류가 이어지는 지점을 찾아 권한 상승까지 따라간 뒤 원인과 개선안을 보고서로 정리했습니다.

Docker 컨테이너 보안 가이드

공개 문서

github.com/ki0915/Docker-Security-Guide [소개 페이지 ↗](#)

OWASP Docker Top 10, CIS Docker Benchmark, NIST SP 800-190을 작은 팀이 먼저 할 일 순서로 정리했습니다.

기술

SKILLS

보안	침해사고 대응, 이상행위 조사, IIS 로그와 시스템 로그 분석, 접근통제(RBAC), 계정 정책, 방화벽과 Security Group 정책, 서버 운영 점검 기준(체크리스트), 취약점 진단과 조치, DLP, SAST, SARIF, CWE, CVE
인프라	Windows Server 2022, IIS, Hyper-V, Ubuntu, AWS(EC2, RDS), Docker, SSL VPN, Grafana, Prometheus
개발	Python, TypeScript, Node.js, cron, MSSQL, MariaDB, Redis, GitHub Actions

자격

CERTIFICATIONS

정보보안기사	한국방송통신전파진흥원	2025.05
CISA 시험 합격 (Associate)	ISACA	2024.07
CLLMSP (LLM 보안)	Red Team Leaders	2026.07
정보처리산업기사	한국산업인력공단	2023.09
Azure Fundamentals (AZ-900)	Microsoft	2022.08
네트워크관리사 2급	ICQA	2021.11

학력과 교육, 어학

EDUCATION

정보보호학 학사	학점은행제	2026.08
컴퓨터보안 전문학사	명지전문대학	2026.02
케이샐드 주니어 (80시간)	KISA	2024.11
TOEIC Speaking IH (140)	ETS	2025.07